

AJNAT SOC

Complete Workflow, User Roles & Access

Who does what, which data each user can access, and how incidents are closed.

Version 1.0 | 3 October 2026 | English

This guide is based on the application code in this repository. It covers the workflow from company setup through endpoint monitoring, alert detection, analyst assignment, response, closure review and reporting.

Covered users: Partner Admin, Company Admin, Department Admin, SOC Manager, L1 Analyst, L2 Analyst, L3 Analyst, L4 Threat Intelligence Analyst and legacy Analyst.

Main operating flow

Company setup → Team and scope assignment → Agent installation → Monitoring → Detection → Ticket or Incident → Investigation → Response → Closure review → Reporting and improvement

How to read this document

- Business/admin team: read sections 1–6, 10–12 and 21.
- SOC analysts: read sections 7–9 and 13–23.
- Access review: read sections 3, 9, 19 and 23 together.
- Source verification: section 24 lists the relevant code files.

Reading note: “Allowed” means that the role gate for the listed backend operation permits the role; company/department scope, resource ownership, account state and operation-specific checks still apply. Menu visibility does not imply action permission. This is a static code review; live user names, live assignments, production configuration and actual enforcement results have not been verified.

1. Workflow overview

Section	What you will learn
2–3	End-to-end system flow and data access boundaries
4–5	Responsibilities of Partner, Company and Department Admins
6	Daily responsibilities of the SOC Manager
7–8	Tasks for L1, L2, L3, L4 and legacy Analysts
9	Administrative and technical permission tables
10–12	Company onboarding, team setup and endpoint deployment
13–14	Purpose of all 31 EDR capability cards
15–16	Alert, ticket, incident and assignment rules
17–18	Investigation, escalation and closure audit
19–20	Encryption, SOAR and response execution
21	Forensics, communication, reports and shift handover
22	Practical incident examples
23–24	Current implementation differences and source references

Seven essential points

1. **Partner Admin** manages the partner's companies and commercial operations.
2. **Company Admin** manages the company's departments, assets, users and settings.
3. **Department Admin** has an operational view of the assigned department and limited management access.
4. **SOC Manager** manages SOC teams, shifts, queues, approvals and reviews for assigned companies.
5. **L1 → L2 → L3 → SOC Manager** is the normal escalation chain.
6. **L4** is a Threat Intelligence specialist. It is not the next standard escalation level after L3.
7. An alert can become a **ticket** or evidence for an **incident**. The case-exclusivity service prevents duplicate ownership across the two.

Role and access comparison

User group	Main control
Partner / Company admins	Organization, users, assets, commercial setup and permitted administration
Department Admin	Department operations; some technical manager actions, but no company-wide user/asset CRUD
SOC Manager	SOC operations, analyst assignments, response approvals and closure reviews
L1–L3	Triage, investigation and advanced response analysis, with role-specific technical permissions
L4	Threat Intelligence cases and scoped network ticket visibility
Legacy Analyst	General monitoring role, separate from dedicated SOC-tier access

Access is not measured as a percentage. The relevant questions are which company, department, case and action the user is authorized to access.

2. How the SOC works end to end

System flow

01 Company / Department / Assets	02 Endpoint agent + configured network / web / identity sources	03 Authenticated ingestion + company scope + subscription checks
04 Event normalization, event IDs, storage and enrichment	05 Detection rules + correlation + configured Threat Intelligence / AI	06 SOC work queue → Ticket or Incident → Assigned analyst
07 Investigation → Supported response → Endpoint result	08 Closure → Audit review → Reports → Rule / process improvement	

Step	What happens	Main owner / output
1	Company, department, subscription and asset records are prepared.	Company Admin; Partner Admin where applicable
2	Users receive roles, company assignments, optional departments and shifts.	SOC Manager / authorized admin
3	The agent is installed; identity, heartbeat and supported sensors are reported.	Authorized admin + endpoint operator
4	Process, file, network, authentication and other configured telemetry is collected.	Agent / integrations
5	The backend validates incoming scope and stores normalized events.	API; optional broker/worker
6	Security-relevant events are enriched and correlated.	Detection / correlation services
7	An actionable item enters the queue; a ticket or incident owner is selected.	SOAR / routing service / SOC Manager
8	The analyst reviews evidence, timeline, severity and impact.	L1, L2, L3 or L4
9	A response is dispatched according to the rule mode or authorized approval.	SOAR / manager / permitted admin
10	Endpoint acknowledgement and results record the response outcome.	Agent + response service
11	The case is closed; eligible incident closures enter a higher-role audit.	Assigned analyst + reviewer
12	Reports, audit trails and handovers provide context to the next shift and management.	SOC Manager + admins

Role of data services

MongoDB stores application records, alerts, incidents and assignments. Code paths exist for Kafka ingestion, ClickHouse analytics, Redis scaling and object archives, but their use depends on deployment configuration. The browser dashboard uses REST APIs and live socket updates. External AI, reputation feeds and Velociraptor must be configured and reachable. [S10, S11, S14]

3. User hierarchy and data scope

Organizational relationship

Partner Admin → the partner's companies

Company Admin → own company → departments → assets and company users

SOC Manager → assigned companies → managed L1 / L2 / L3 / L4 analysts

Analyst → assigned companies → optional assigned departments → personal cases / permitted shared queues

This is a responsibility map. Roles do not automatically inherit every permission of other roles. For example, Partner Admin is a senior commercial role but is not included in the Encryption Center permission list.

An employee/OS user working on an endpoint may be subject to monitoring; this does not automatically grant a SOC dashboard account or analyst permissions.

Role	Data scope	Main restriction
Partner Admin	Companies linked to the partner	No authorized scope for unrelated partners/companies
Company Admin	Own company	No automatic access to another company
Department Admin	Assigned department within own company, on department-aware routes	Company-wide administration and department-limited views are separate
SOC Manager	Active SOC company assignments; primary-company fallback in the helper	The role title alone does not grant access to all companies
L1 / L2 / L3	Assigned companies; narrower scope with department mappings; own assignments in personal queues	Another analyst's case does not become the user's own case
L4	The same scope rules; T1 incidents and permitted network ticket views	General SOC alerts list explicitly blocked; shared read access does not grant ownership
Legacy Analyst	General company scope; department/assignment filters on selected routes	Dedicated L1–L4 route gates do not accept this role

How effective access is determined

1. **Identity:** whether the login token is valid.
2. **Role:** whether the endpoint's role gate allows the user.
3. **Scope:** whether the company / department / tenant is authorized.
4. **Resource:** whether the record belongs to that scope and is assigned to the user for personal actions.
5. **Operation:** whether approval, fresh MFA, a subscription or an agent capability is required.

The SOC dashboard also rechecks account status and token-role freshness. Not every generic API repeats these checks; this guide does not claim globally immediate session revocation.

Important department assignment behavior

SOC data helpers narrow the filter when active department mappings exist. Without mappings, assigned-company scope may remain. Therefore, **“a blank department means zero access” is not the current rule.** Different modules use their own filters; section 23 explains the practical limits. [S1, S2, S5]

4. Partner Admin responsibilities and access

Role code: partner_admin | **Main screen:** /partner/companies

Responsibilities

- Manage the overview, status and commercial relationships of companies linked to the partner.
- Send company registration invitations; the registration link carries the partner relationship.
- View authorized company admin / user records and use available management actions.
- Review partner revenue, collection/payment controls, subscriptions and available agent-license balances.
- Follow up on company-support tickets; maintain the partner profile and available pricing settings.
- Manage scoped SOC Manager / L1–L4 invitations and company assignments within management-scope checks.

Daily workflow

1. Review the company list and active/inactive accounts.
2. Send company-registration invitations to new customers.
3. Check customer plan/payment status and agent-license readiness.
4. Coordinate manager / analyst assignments for the required SOC coverage.
5. Resolve company support, renewal and resource requests.
6. Use reports and company incident visibility for service follow-up.

Access boundary

Area	Partner Admin access
Companies	The partner's company list / authorized management
Users	View/update within partner user scope; legacy Analyst through the generic invite flow
SOC staff	Managers and L1–L4 through the SOC invitation flow; eligible staff management scope required
Assets / agent package APIs	Allowed by the company-admin role gate; valid company context required
SOAR approval	Listed approver role; scoped approval resource required
SOAR connectors / credentials	Allowed through the company-admin gate
Encryption Center	Not included in the permission map
New forensic hunt	Not included in the dedicated /forensics hunt launch list; the legacy EDR hunt endpoint uses a different gate
SOC chat	Not included in the dedicated SOC chat role list; partner support uses a separate workflow

Many partner portal operations check for an approved account and an active paid partner plan. The company's own subscription/agent entitlement is checked separately. Access to the partner portal does not prove that telemetry is active for every company. [S1, S3, S8, S9, S12]

5. Company Admin and Department Admin

Company Admin

Role code: company_admin | **Main screen:** /dashboard/company-admin

Responsibility: keep the company operationally ready and act as the business owner of the security service.

- Maintains the company profile, departments, asset records and license allocation.
- Can create a Department Admin account while creating a department.
- Invites legacy Analysts through the general user invite flow; can invite L1–L4 through the SOC flow.
- The company-level user update endpoint allows role/status-related updates. This is a separate path from invitation permissions.
- Manages agent config/package downloads, supported update/revoke operations and asset setup.
- Reviews company incidents, open/closed tickets, reports, settings and notifications.
- Can use SOAR rules/playbooks, connectors, credentials and approval actions within company scope.
- Can encrypt, request/decrypt and export encryption audits; cannot manage keys or approve decryption.

Daily output: accurate asset inventory, assigned department owners, available endpoint coverage, tracked business impact and reviewed reports.

Department Admin

Role code: department_admin | **Main screen:** /department-admin/dashboard

Responsibility: coordinate operations for the department's assets and security issues.

- Views department incidents, open/closed tickets, assets, users and reports.
- Coordinates missing telemetry / affected assets with the Company Admin or SOC Manager.
- Has access to scoped technical actions through manager gates, such as isolation, firewall/IDS/IPS policy management and SOAR rule/playbook operations.
- Is included in the dedicated forensic collection launch role list.
- Can manage custom correlation rules within department scope; is not included in the built-in correlation override/run role list.
- Can read the team list. Is not included in the company-admin gates for generic user invitation/update, department CRUD, system CRUD or agent package downloads.
- Has no SOAR approval, connector/credential management or Encryption Center permissions.

Operation	Company Admin	Department Admin
Department create/edit/delete	Yes	No
View department users	Company scope	Department list
General user invite/update	Yes, route-specific	No
Asset create/edit/delete	Yes	No
Asset monitoring view	Company	Department-aware scope
Isolation / scoped technical policy	Manager gate allowed	Manager gate allowed
SOC team / shift management	Management routes allowed	No; incident/TI list read exception

UI note: Department Admins may see setup/asset screens; screen visibility does not authorize CRUD operations. [S1, S3, S4, S7, S8, S9]

6. Complete SOC Manager workflow

Role code: soc_manager | **Main screen:** /soc-manager/dashboard

Responsibility: own SOC operations, workload and case quality for assigned companies.

Stage	SOC Manager action	Output
Coverage	Check assigned companies, active agents and team availability	Monitoring gaps / coverage picture
Staff	Manage L1–L4 invitations, status, permitted profile updates and assignments	Active analysts with correct scope
Shift	Set company, timezone, days, start/end times and analyst roster	Shift coverage
Queue	Review unassigned alerts/incidents and SOAR tickets	Eligible analyst assignment
Escalation	Accept/reject/resolve L3 escalations; add a decision note	Ownership and next action
Response	Handle permitted policy actions and SOAR approvals	Recorded response decision
Review	Perform standard audits of L3 closures and threat audits of L4 closures	Approved closure or changes requested
Reporting	Review workload, cases, activity, reports and audits	Handover / management update

Staff management limits

SOC Managers can invite L1–L4 analysts. This SOC invitation flow does not permit them to invite another SOC Manager. Staff management checks the target's companies, partner/origin scope and existing manager relationship. An analyst explicitly managed by another manager is not assumed to belong to the current manager.

Technical access

- IDS/IPS/Firewall management and automatic-response manager gates allow this role.
- SOAR catalog/rule/playbook operations and SOAR approvals are allowed.
- Correlation rules and manual correlation runs are allowed.
- Forensic hunt launches and evidence integrity verification are allowed.
- Encryption Center key management, approval, encrypt/decrypt and audit export are allowed; fresh MFA and scope checks apply.
- SOC Manager is not included in the company-admin gates for SOAR connector/vault credential management or agent package downloads.

Recommended daily sequence

At shift start: coverage → unassigned/critical queue → pending response approvals → analyst blockers → closure reviews → company updates → next-shift handover.

A workload field on the dashboard does not prove a hard assignment cap. Routing primarily uses eligible roles and case loads; section 23 explains maxWorkload enforcement. [S1–S9]

7. L1 and L2 Analyst workflows

L1 Analyst — initial triage

Role code: I1_analyst | **Screen:** /I1/dashboard

Input: eligible low/medium security work, assigned tickets/incidents and permitted queue items.

1. Check your shift and queue.
2. Acknowledge the case; claiming an eligible unassigned item establishes ownership.
3. Review event time, system, department, rule, severity and raw evidence.
4. Distinguish duplicates, expected activity and actual suspicious behavior.
5. Record observed facts, the affected asset and the reason for the decision in notes.
6. If the investigation is complete, resolve or mark false_positive; escalate unresolved or advanced cases to L2.
7. Closing an incident creates a review in the L2 standard audit queue.

Access: acknowledge, investigate, note, resolve, false-positive and escalate actions on owned cases. General forensic viewing may be available; L1 is not in the new hunt launch list. SOAR rule administration, live network policy changes and Encryption Center access are not permitted.

Output: triage result, evidence notes, a closed incident for review or an L2 escalation.

L2 Analyst — detailed investigation

Role code: I2_analyst | **Screen:** /I2/dashboard

Input: high-severity items, assigned investigations and L1 escalations.

1. Review L1 context and incoming escalations.
2. Correlate process/file/network/auth evidence into a timeline.
3. Identify affected assets, suspicious indicators and incident impact.
4. Launch authorized forensic collection when required.
5. Record response recommendations and supporting evidence; coordinate operational responses through a manager or permitted automation.
6. Approve audits of L1 incident closures or request changes.
7. Closing your own case triggers L3 review; escalate complex/critical investigations to L3.

Access: L2 and lower-tier route gates, scoped investigation actions, forensic hunt launches and encryption view/decrypt requests. Actual decryption requires an approved request and fresh MFA. Encrypt/upload, key management, crypto approval and SOAR approval are not permitted.

Implementation note: /I2/incidents/:id/run-playbook records an audit event and returns a success response, but the handler does not dispatch real SOAR execution. The button/response is not proof of successful endpoint action. [S5, S6, S8, S9]

8. L3, L4 and legacy Analysts

L3 Analyst — advanced investigation

Role code: I3_analyst | **Screen:** /I3/dashboard

The primary work includes critical cases, L2 escalations, root-cause analysis, hunting and detection improvement. L3 reviews process chains, persistence, lateral movement and impact to produce an RCA. L3 reviews L2 closures and submits its own incident closures to the SOC Manager for standard audit. Unresolved issues are escalated to the SOC Manager.

Allowed technical work: dedicated forensic hunts; custom correlation rules, built-in overrides and manual runs; encryption view/encrypt/request/decrypt. General SOAR rule administration and SOAR approval gates do not allow L3. The dedicated L3 playbook route creates an approval_required record; this does not automatically create an active production playbook.

L4 Threat Intelligence Analyst

Role code: I4_analyst | **Screen:** /I4/dashboard

Specializes in Threat Intelligence incidents, malicious/suspicious IOCs and external reputation context.

- Reviews the IP/domain/hash, confidence, affected endpoint and linked evidence of assigned TI incidents.
- Assesses IOC freshness, source and the actual endpoint/network relationship.
- Investigates, adds notes to and closes owned TI incidents.
- Closures go to the SOC Manager's **threat audit**.
- Can view shared IDS/IPS/Firewall SOAR tickets within permitted company/department scope; seeing another owner's ticket does not grant edit ownership.
- Dedicated forensic hunts and encryption view/encrypt/request/decrypt are permitted.
- IDS/IPS/Firewall pages are available, but policy-change manager gates do not allow L4.
- General SOC alerts listing is explicitly blocked for L4.

Escalation note: the current NEXT_LEVEL mapping and escalation schema do not define a standard next level for L4. Raise operational blockers through manager chat/support; the normal Escalate action is not a supported L4 path.

Legacy Analyst

Role code: analyst

This is the older general company analyst role. It may be allowed on general monitoring/read endpoints. The frontend dashboard mapping uses the L1 route, but dedicated SOC dashboard and L1/L2/L3 backend role gates do not accept legacy Analysts.

Do not assign legacy Analysts access equivalent to L1. Use explicit L1/L2/L3/L4 roles and company assignments for new tiered SOC work. [S1, S5–S9, S13]

9. Access by role

Y = listed role gate allows; N = listed role gate does not allow. Every Y applies within valid resource scope. These tables cover named APIs; section 23 explains differences in alternate/legacy endpoints.

Administrative roles

Operation	Partner	Company	Dept	SOC Mgr
Department create/edit/delete	Y	Y	N	N
System create/edit/delete	Y	Y	N	N
Agent package/config/update	Y	Y	N	N
Generic user update	Y	Y	N	N
SOC L1–L4 invitation	Y	Y	N	Y
SOC Manager invitation via SOC flow	Y	N	N	N
SOC staff assignments / shifts	Y	Y	N	Y
IDS/IPS/Firewall policy writes	Y	Y	Y	Y
System isolation / release manager gate	Y	Y	Y	Y
SOAR rule/playbook management	Y	Y	Y	Y
SOAR approvals	Y	Y	N	Y
SOAR connectors / vault credentials	Y	Y	N	N
Custom correlation rules	N	Y	Y	Y
Built-in correlation override / run	N	Y	N	Y
Dedicated forensic hunt launch	N	Y	Y	Y
Dedicated SOC incident action route	N	N	N	Y

Company/Department admins may have other EDR/monitoring management routes. An N for the dedicated SOC incident-action route does not deny all incident access. Company Admin has a specific SOC incident-detail read exception; Department Admin has a manager incident/TI list read exception.

SOC analyst roles

Operation	L1	L2	L3	L4	Legacy
Own SOC case investigate/note/close	Y	Y	Y	TI	N
Standard next-level escalation	L2	L3	Mgr	N	N
New forensic hunt launch	N	Y	Y	Y	N
Correlation rule management / run	N	N	Y	N	N
General SOAR rule writes / approval	N	N	N	N	N
IDS/IPS/Firewall policy writes	N	N	N	N	N
System CRUD / agent package download	N	N	N	N	N
SOC staff / shift administration	N	N	N	N	N
Encryption access	N	Limited	Y*	Y*	N

*Encryption Y does not mean full administration; section 19 provides the exact table. General read access for legacy Analysts is separate from dedicated SOC access. Staff scope, company selection, optional department mappings and personally assigned cases can further restrict actions. [S1–S9]

10. Company onboarding and login workflow

A. Company onboarding

- 1. The company completes direct or partner-linked registration.
- 2. The Company Admin identity is linked to the company record.
- 3. The required plan, system/server/phone quantities and payment flow are completed.
- 4. The Company Admin sets up departments and license allocation.
- 5. Department owners, users and SOC team coverage are configured.
- 6. Assets are created and agent deployment begins.
- 7. Heartbeat / telemetry verification establishes operational coverage.

B. How subscriptions affect monitoring

Check	Result
Company active + valid base/add-system entitlement	Ingestion allowed
Company inactive	Monitoring stop/block response
License inactive/expired	Telemetry blocked until eligible renewal/reactivation
Department allocation exceeds purchased limit	Allocation validation error where a positive limit is configured

The base subscription and add-system batches are independent entitlement sources. Base-plan expiry alone does not determine final coverage; the entitlement helper calculates the combined state. Blocked ingestion responses include a subscription code and the stop_monitoring flag.

C. User login

Email/password → configured verification / 2FA checks → token → role-aware dashboard → API-specific authorization.

The user model supports invited, active, disabled, suspended and expired account states. Email verification, force-password-reset and TOTP/2FA-related fields are available. Passwords are hashed with Argon2id; rolling migration code runs after successful legacy bcrypt logins.

D. Account changes

An admin changes staff status or role → updated assignment/account checks apply → users may need to log in again when a stale role is detected. The SOC dashboard checks role freshness. Generic JWT middleware only verifies the token, so immediate disable/role-change effects should not be assumed on every endpoint.

Operational output: an active company, verified operator identities, valid license capacity, clear department ownership and correctly mapped SOC accounts. [S1, S3, S4, S10, S12]

11. SOC team invitations, assignments and shifts

From invitation to active analyst

01 Authorized manager/admin selects name + email + role + companies + optional departments	02 Scope validation; selected companies within one tenant	03 Pending SOC invitation + hashed token + expiry
04 User sets name/password through accept-invite	05 Active user + company/department assignment records	06 Manager relationship, shift roster and readiness for case assignment

SOC invitations expire after **48 hours** in the current flow. Duplicate active invitations/emails and invalid company/department selections are rejected. Resend/revoke management actions use scope checks.

Who can invite users

Inviter	SOC invitation roles
Partner Admin	SOC Manager, L1, L2, L3, L4
Company Admin	L1, L2, L3, L4
SOC Manager	L1, L2, L3, L4
Department Admin / analyst tiers	SOC invitation route not allowed

Generic user invitation is a separate flow through which Partner/Company Admins invite legacy Analysts. Department Admins can be created during department creation. Generic role update permissions are separate from the invitation role list.

Assignment fields

- **Company assignment:** the companies the analyst will work on.
- **Department assignment:** an optional mapping for narrower data access.
- **Manager relationship:** the manager whose team the analyst belongs to.
- **Shift roster:** company, timezone, weekdays, start/end times and analyst list.
- **Case assignment:** the current owner of a specific alert/ticket/incident.

These five settings do not replace one another. Being listed on a shift does not grant access to an unassigned company's data.

Shift rules

Shift creation/update validates active analysts and company assignments. Analysts see only their assigned active shifts; managers see the broader authorized schedule. Time handling supports overnight shifts.

For Indian operations, explicitly set the timezone to **Asia/Kolkata**; the backend may default to UTC. Assignments are not automatically revoked at shift end. SOAR routing prefers on-shift candidates but falls back to active, company-scoped users with eligible roles when no suitable on-shift user is available. [S2–S5, S7]

12. Endpoint installation and telemetry workflow

Deployment steps

Step	Action	Responsible
1	Check company plan, asset type and department allocation	Company/Partner Admin
2	Create the system/asset record; attach the correct company/department	User allowed by the company-admin gate
3	Generate/download the system-specific package/config	Authorized Company/Partner Admin
4	Install the package on the endpoint; configure required OS permissions/sensors	Endpoint operator / IT owner
5	Establish agent identity/enrollment and heartbeat	Agent + backend
6	Inspect version, lastSeen, sensors and license state	Admin / SOC Manager
7	Verify real telemetry and supported response results	SOC operations

What the agent sends

Heartbeats include endpoint identity, OS/version, agent version, enabled capabilities and sensor state. Collectors gather configured process, file, network, log, USB, credential, data-security and other activity. The repository includes a Python desktop agent and Android-related implementation; equal capability depth across all operating systems is not assumed.

Delivery and storage

1. The agent prepares local events and may use stable event IDs.
2. A durable spool / queue retains events; failed deliveries are retried.
3. Signed/authorized transport carries data to the backend endpoint; legacy compatibility may depend on deployment.
4. The backend validates authoritative system/company scope and entitlement.
5. Direct ingestion or a configured Kafka worker persists events.
6. Normalized records become inputs for monitoring views, correlation and SOAR.

Interpreting health correctly

- **Agent online:** a recent heartbeat exists.
- **Sensor ready:** the required collector/integration is available.
- **Telemetry present:** actual events are arriving.
- **Response successful:** the requested command has a confirmed endpoint result.

Do not infer all four states from a single green “online” indicator. For example, an agent may be online while its packet sensor is missing; an IDS event may be visible while inline IPS enforcement is inactive.

Blocked subscriptions, identity mismatches, offline endpoints, unsupported capabilities and pending acknowledgements are separate operational outcomes. [S10, S11, S14]

13. EDR capabilities – 1 to 16

The current frontend capability catalog contains **31 cards**. Each card's use in analysis is described below; actual coverage depends on the OS, configured collector, permissions and incoming evidence.

ID	Capability	What the analyst reviews / investigates
1	Process Activity Monitoring	Process start/stop, parent-child chains, command/context and suspicious execution
2	File Activity Monitoring (FIM)	File create/modify/delete/rename and integrity-related changes
3	Network Activity Monitoring	Connections, source/destination, ports, process context, DNS and geolocation evidence
4	User & Authentication Monitoring	Login failures/successes, account actions, remote access and privilege-related events
5	Memory Activity Monitoring	Memory usage/activity and suspicious memory signals; normal resource usage is not a threat
6	Registry Monitoring	Windows registry changes, sensitive keys and configuration/persistence context
7	System Changes Monitoring	System configuration changes and authorized/unauthorized change investigation
8	Persistence Mechanism Detection	Startup entries, scheduled tasks, services and other persistence indicators
9	Web & DNS Monitoring	Domain/web activity, suspicious destinations and DNS context
10	Device Control (USB) Monitoring	USB insertion/activity, policy violations and supported device-control evidence
11	Behavioral Analytics (UEBA)	User behavior baselines, deviations and profile-mismatch investigation
12	Data Security Monitoring	Sensitive-data activity and potential movement/exfiltration signals
13	Credential Security Monitoring	Credential access, suspicious use of authentication material and related evidence
14	Lateral Movement Detection	Remote execution/auth patterns and suspicious movement between systems
15	Email Threat Monitoring	Email-related threat indicators, attachments/links and available source evidence
16	Insider Threat Detection	Combined insider-risk context from user behavior and security signals

Role handoff

L1 triages routine actionable items; L2 handles high/complex cases; L3 handles critical/advanced cases; L4 handles TI/IOC-classified cases. Company/Department Admins explain affected assets and business activity. The SOC Manager coordinates coverage, policies and response.

Not every monitoring row should become an incident. The SOC queue filter excludes routine process/file/network summaries and synthetic items; relevant actionable/security signals drive the queue. [S2, S13, S14]

14. EDR capabilities – 17 to 31

ID	Capability	What the analyst reviews / investigates
17	Patch & Vulnerability Monitoring	Patch/software inventory and exposure context
18	Sandbox Analysis	Configured sandbox availability and available analysis results
19	Kernel-Level Monitoring	Available kernel/driver/security telemetry and sensitive low-level activity
20	API Call Monitoring	Available API-call evidence, unusual usage and correlated activity
21	Script Execution Monitoring	Script/command execution, interpreters and suspicious behavior
22	Time-Based Anomaly Detection	Unusual timing / exceptions outside expected activity windows
23	Geolocation Anomaly Detection	Unusual locations, travel/session patterns and geolocation protection evidence
24	Service Monitoring	Service creation, state/configuration changes and suspicious service use
25	Hash/Signature Analysis	File hashes, signature/baseline evidence and reputation context
26	Beaconing Detection	Repeated/patterned network connections and possible C2 behavior
27	Encryption / Ransomware Detection	Suspicious encryption/file activity and ransomware indicators
28	Living-off-the-Land (LOLBins) Detection	Suspicious use of legitimate system tools
29	Memory Overflow Detection	Overflow/exploit-like memory signals
30	DNS Cache Poisoning Detection	DNS trust/cache anomalies and configured protections
31	DNS Sinkhole	Configured malicious-domain redirection/blocking and sinkhole events

Supporting SOC modules

Module	Role in the workflow
SIEM / Log Monitor	Search and review security events
IDS	Network attack/anomaly detection; configured Suricata/Zeek/generic inputs
IPS / Firewall / WAF	Supported policy enforcement, block decisions and acknowledgement tracking
Correlation	Build an attack timeline / incident context from related events
SOAR	Triggers, conditions, approvals and supported action sequences
Forensics	Evidence collection, output, hashes and custody trails
Encryption Center	Scoped encrypted records/evidence and controlled decryption
Security Score / Compliance / Reports	Summaries, posture and review outputs
Fraud Intelligence	Available partner-facing workflows for account/payment-related fraud review

Catalog caveat: the current SOC role-routing helper also treats capabilityIds containing 29 as a TI indicator, while card 29 in the current catalog is Memory Overflow. This mismatch may route some items to L4. Review section 16 routing results against the actual classification fields. [S2, S12–S14]

15. Differences between alerts, tickets and incidents

Record	Meaning	Typical contents
Event / log	Activity observed at a source	Timestamp, host, user, process/network/file details
Alert	Detection/security record; not every alert is a confirmed attack	Rule, severity, evidence, IOC/enrichment fields
Ticket	Operational work item, often an Alert record opened through SOAR	Open time, source, category, owner, routing/audit history
Correlation event	Detected pattern across related signals	Matched evidence, confidence, status, assignment
Incident	Investigation case linked to multiple alerts/correlation	Impact, IOC list, affected asset, notes, response/AI context

From detection to case creation

1. Incoming events are normalized and stored.
2. The security-relevance filter separates routine telemetry and synthetic noise.
3. Configured detection, IOC enrichment and correlation identify related activity.
4. Correlation may set the incident source to EDR or threat_intelligence.
5. A SOAR rule may request an action such as create_ticket or create_incident.
6. The case-claim service checks existing ticket/incident ownership.
7. Eligible cases become visible in analyst/manager queues.

Preventing duplicate ownership

A request to create a SOAR ticket from an alert already linked to an incident may be rejected/skipped. The incident claim path excludes ticket-opened / SOAR-ticket alerts. Therefore, “every alert → ticket first → incident next” is not a mandatory chain; tickets and incidents are alternative case paths.

Role of AI

The incident model supports queued, processing, completed, failed and not_required AI investigation states. Available output may include a summary, root cause, confidence, reasoning and recommended steps. This provides investigation context; response execution and endpoint evidence are needed to confirm a response.

AI output will not be available for every incident if AI/external reputation services are unconfigured or fail. Incident existence, completed AI analysis and endpoint containment are three separate states.

Investigation evidence: source alerts, process/file/network context, related correlation, notes, observed IOCs, affected users/systems, response logs and forensic results. [S5, S8, S11]

16. Ticket and incident assignment

Routing priority

Work item condition	Eligible target
SOAR ticket source matches IDS / IPS / Firewall / Suricata / Zeek classification	SOC Manager or L4
Other TI-classified work items	L4
Other critical-severity items	L3
Other high-severity items	L2
Other low / medium-severity items	L1

The network SOAR ticket exception applies before severity/TI fallback. A general network category alone is insufficient for this exception; matching source evidence is also required.

TI classification uses inputs such as incidentSource, ticketCategory, THREAT_FEED, iocMatched, qualifying TI confidence, malicious/suspicious VT verdicts and the current capability-ID condition. Section 14 explains the capability 29 mismatch.

Automatic SOAR ticket assignment

1. An exclusive ticket claim is placed on the alert.
2. Ticket source/category and opened/queued timestamps are set.
3. The ticket first enters the SOC Manager queue; notification/audit records are created.
4. Active, company-assigned candidates with the required role are identified.
5. Candidates from the relevant department may be preferred or the pool narrowed; the manager-eligible ticket path behaves differently.
6. Eligible candidates currently on shift are preferred. Otherwise, eligible active company users are the fallback.
7. Selection uses the lowest same-category load, then lowest total load, then stable ID order.
8. Owner and auto-routing fields are set; an open ticket may become investigating.
9. If no eligible user is found, the ticket remains unassigned in the manager queue.

Manual / other assignment paths

The SOC Manager work-item assignment endpoint validates item scope and the required role. A user can be selected explicitly; the IDS/IPS/Firewall SOAR ticket path enforces automatic eligible selection. The generic assignment path without a specified user uses configured shift membership and total load; it is not the exact SOAR ticket routing algorithm.

TI correlation incidents have a separate auto-assignment path using active assigned L4 analysts, optional department preference and workload. Normal EDR incidents support the manager queue/assignment workflow; do not assume every new incident is automatically assigned immediately.

No eligible user: the manager must fix coverage/assignments. Assignment may be rejected if the selected analyst role does not match the severity requirement. [S2, S4, S7, S11]

17. Investigation and escalation workflow

Normal case sequence

Open / unassigned → eligible assignment / acknowledge → Investigating → evidence and notes → response / escalation → Resolved or False Positive

The incident schema also supports a contained state. Ticket views may show an under_observation state. Cases do not have to pass through every state; the endpoint response lifecycle is tracked separately.

Analyst investigation steps

Step	Analyst action	What the record should contain
Acknowledge	Confirm case ownership	Owner and current status
Validate	Verify source, timestamp, asset and rule	Evidence reliability and scope
Investigate	Assess linked activity and impact	Timeline, IOCs and affected users/assets
Decide	Determine benign/false-positive activity, confirmed threat or need for more analysis	Reason and supporting facts
Respond	Coordinate supported containment/remediation	Requested action, approval, execution ID/result
Close/escalate	Act according to the outcome	Closure note or escalation reason

Escalation chain

L1 → L2 → L3 → SOC Manager

An escalation record may include source user/level, target level, company/department, alert or incident reference, priority, reason, summary, observed IOCs and affected asset.

Required: reason. **Useful handover context:** what was observed, what was verified, what action was taken, its result and what the next analyst needs to do.

Targets are selected using active role/company assignments. If no eligible target is found, escalation assignedTo may remain null. The item remains investigating; the manager must resolve the ownership gap.

Escalation states

State	Meaning
pending	Escalation raised; decision/handling pending
accepted	The manager accepted the escalation
rejected	The manager rejected it; an explanatory note provides essential operational context
resolved	Escalation resolved or synchronized with linked incident closure

The SOC dashboard escalation-status endpoint allows only the SOC Manager to update accepted/rejected/resolved states. The alert escalation path blocks duplicates at the same target level. Standard L4 escalation mapping is unavailable; manager contact and threat audit provide separate paths. [S5, S6]

18. Incident closure and audit review

Closure reviewers

Analyst closing the incident	Reviewer	Audit type
L1 Analyst	L2 Analyst	Standard
L2 Analyst	L3 Analyst	Standard
L3 Analyst	SOC Manager	Standard
L4 Analyst	SOC Manager	Threat

Current closure sequence

1. The assigned analyst selects resolve or false_positive.
2. Incident status updates immediately; resolvedAt and closedBy are set.
3. The applicable higher-role review is created/updated in pending state.
4. Linked correlation and related alert statuses are synchronized.
5. Linked pending/accepted escalations may be resolved.
6. The reviewer checks the evidence and analyst decision.

Important: the current design closes the incident first and leaves the subsequent review pending. Closure is not deferred until approval.

Reviewer decision

Decision	System behavior
Approve	Review approved; reviewer/time/note recorded
Request changes	Review changes_requested; note required
Effect of changes requested	Incident becomes investigating; closure metadata cleared; reassigned to the original submitter
Linked evidence	Main linked alerts/correlation updated to investigating

After rework, the analyst can close the incident again; the submission count increases. Reviewers need a pending review for their reviewerRole and authorized company/department scope.

Recommended closure record

- **Finding:** the actual issue and affected endpoint/user.
- **Evidence:** key event IDs, timestamps, IOCs and forensic evidence.
- **Action:** what was blocked/isolated/remediated and who approved it.
- **Result:** endpoint confirmation / validation evidence.
- **Disposition:** resolved or false positive, with a reason.
- **Follow-up:** remaining patch/policy/task and its owner.

Plain alert/ticket closure does not automatically create the same higher-role incident-audit object. There is also no CLOSURE_AUDIT_ROUTE entry for SOC Manager closures. Alternate EDR/correlation status endpoints should not be treated as equivalent to this review path. [S5, S11]

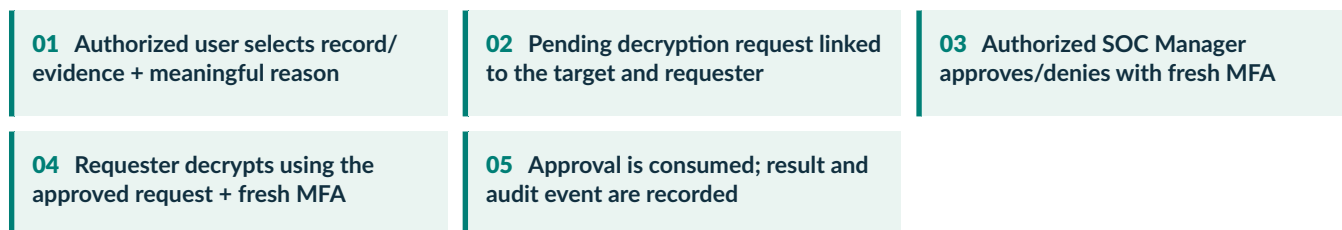
19. Exact Encryption Center access

Permission matrix

Role	View	Encrypt	Request decrypt	Decrypt*	Approve*	Keys*	Audit export
Company Admin	Y	Y	Y	Y	N	N	Y
SOC Manager	Y	Y	Y	Y	Y	Y	Y
L2 Analyst	Y	N	Y	Y	N	N	N
L3 Analyst	Y	Y	Y	Y	N	N	N
L4 Analyst	Y	Y	Y	Y	N	N	N
Partner / Dept / L1 / Legacy	N	N	N	N	N	N	N

Y/N has the same meaning as in section 9. A decrypt role permission does not immediately grant plaintext access.

Encrypted data access flow



Conditions

- Company/tenant scope is validated; arbitrary decryption of another company's data is not allowed.
- Requests require a meaningful reason; the current handler checks a minimum of 8 characters.
- Default request expiry is 30 minutes; configuration may change it.
- The default maximum age for fresh MFA is 15 minutes; configuration may change it.
- Applicable fresh-MFA checks cover key creation/rotation/revocation and approval/decryption.
- Self-approval is blocked by default. An explicit deployment override may exist, so the live setting is not assumed.
- Approval is tied to the target/requester and its consumption is controlled.

How SOC Managers handle their own requests

With the default self-approval restriction, another authorized SOC Manager in the same scope must approve the request. If no such approver is available, the request may remain pending or expire; role permission does not automatically allow self-approval.

Encrypted evidence storage, integrity/custody and decryption audits support investigation traceability. Crypto audit export permission is separate from forensic hunt launch and SOAR vault permissions. [S9]

20. SOAR and response execution

From rule to action

Alert trigger → enabled rule match → conditions → ordered steps / playbook → execution mode → approval if required → response dispatch → endpoint acknowledgement/result → outcome log

Actions may include case creation, assignment/status changes, notifications and supported endpoint/network responses: isolate/release, process termination, file quarantine/restore, IP/domain/hash/port blocks, USB control, account/session and service-related actions. Actual support depends on the agent/platform and action handler.

When approval is required

Path / mode	Current behavior
SOAR rule automatic	Pipeline runs without a human pause; high-risk steps may also run automatically
SOAR rule approval_required	Execution/step approval gate applies
Other SOAR mode + step requireApproval	The step's approval condition is relevant
Separate automated-response path	Uses high-risk action / force / global approval logic

The current code does not support the claim that **every risky action always requires manual approval**. Reviewing the rule mode before an action is part of the workflow.

Approval owner

SOAR approver roles include Partner Admin, Company Admin and SOC Manager. Department Admin and L1–L4 are not included. Being able to view an approval list does not grant approval permission.

Endpoint result lifecycle

Created → Waiting approval / Approved → Queued → Sent to agent → Acknowledged → Executing → Successful / Partially successful / Failed / Timed out

Cancel and supported rollback states are also available. Actions reach endpoints through the socket/heartbeat command channel. Endpoint results update backend response state and the audit trail.

Operational completion: API command acceptance ≠ successful endpoint action. Analysts should check the response ID, final result, affected target and enforcement evidence. Do not mark an offline endpoint as “protected” while its action is pending or timed out.

Governance

The SOC Manager / authorized admin should maintain rule conditions and scope. L3 can suggest/manage detection improvements through permitted correlation/L3 routes. Connector/vault secret management gates are limited to Company/Partner Admins. [S1, S6, S8]

21. Forensics, communication and reporting

Forensic collection

Select incident / endpoint → authorized hunt launch → configured Velociraptor collection → completion/output sync → evidence record → hash/integrity + chain of custody → investigation use.

Dedicated /forensics launch roles are Company Admin, Department Admin, SOC Manager, L2, L3 and L4. L1/legacy Analysts do not have launch permission. Partner Admin is not in the dedicated launch list, but the legacy /edr/velociraptor/hunt route has a different company-admin gate.

When reviewing evidence, check the artifact, collection time, requester, size/hash, integrity state and custody events. Reading encrypted evidence may require the section 19 decryption flow. Do not assume collection is complete if the integration/client is missing.

Communication relationships

User	SOC chat relationship
Company Admin	SOC Managers assigned to the company
Department Admin	Relevant department / company-wide SOC Managers
SOC Manager	Managed analysts and scoped Company/Department admins
L1-L4	Assigned/eligible managers and permitted team analysts
Partner / Legacy Analyst	Not in the dedicated SOC chat role list; available support uses a separate workflow

Case notifications, assignment notifications and chat read/unread states are available. Email delivery depends on the configured mail service. Chat messages do not replace formal escalation/review records.

Reports and daily operations

- Analysts should update open cases, blockers, evidence and completed actions.
- SOC Managers should review queue age, role coverage, pending approvals, escalations and closure reviews.
- Company/Department admins should follow up on affected assets, business impact and missing coverage.
- Partner Admins should follow up on customer support, commercial readiness and renewals.
- Reports provide severity/status/category, top systems/rules and resolution-related data. CSV and print-friendly HTML report APIs are available.
- The daily-report service generates company/department reports; reporting windows use UTC dates. Verify the timezone when comparing with local shift/date windows.

Recommended shift handover

Case ID | Company/department | Severity | Owner | Last action/result | Pending approval | Next step | Next owner | Review time.

Some dashboard SLA/MTTR values are static placeholders; do not treat them as measured service commitments. The recommended handover format is operational guidance, not a mandatory product-enforced form. [S4, S5, S9, S15]

22. Practical examples

Example A — medium suspicious login

1. Authentication telemetry produces a suspicious login alert.
2. The item is actionable, non-TI and medium severity; the applicable assignment path selects L1.
3. L1 reviews the user, device, source and expected activity.
4. If the activity is authorized, record false-positive evidence; closing a correlated incident triggers an L2 audit.
5. If suspicion remains unresolved, escalate to L2 with the reason, IOCs and asset context.

Owners: L1 triage; L2 investigation/review; Department Admin business context.

Example B — critical ransomware-like behavior

1. Process/file/encryption signals are correlated.
2. If the case is critical and not TI-classified, L3 is the required role; the manager ensures ownership.
3. L3 investigates the timeline and RCA, using forensic collection as needed.
4. The configured SOAR mode or authorized approval requests supported isolation/quarantine.
5. Endpoint results are confirmed; cleanup/recovery evidence is added.
6. L3 resolves the incident; the SOC Manager performs the standard closure review.

Owners: L3 technical lead; SOC Manager coordination; Company Admin business recovery.

Example C — malicious domain / Threat Intelligence

1. An IOC match and correlated evidence create a TI incident.
2. An active assigned L4 is selected; without an eligible L4, assignment may remain unresolved.
3. L4 verifies the indicator source, freshness and actual endpoint connection.
4. Required blocks/policy changes are applied through the SOC Manager/authorized admin or configured automation.
5. L4 closes the incident with evidence/results; the SOC Manager performs the threat audit review.

Owners: L4 TI analysis; manager/admin enforcement; manager threat review.

Example D — IDS/IPS/Firewall SOAR ticket

1. A SOAR create_ticket step matches a network-security source alert.
2. If there is no incident claim, the ticket enters the manager queue.
3. The source exception selects SOC Manager/L4 candidates, rather than using severity alone.
4. Shift preference and workload determine the owner.
5. L4 can see the ticket in the shared network view; ownership and write permission are checked separately.
6. Ticket closure is recorded in audit history; an incident closure review is not automatically assumed.

These are explanatory examples, not live production cases or measured results. [S2, S5, S7, S8, S11]

23. Important differences in the current code

These points explain the workflow and access accurately. Application behavior was not changed while creating this document.

Finding	Practical effect
Role menus and backend permission gates differ	A visible screen/button does not imply write permission; examples include Department Admin asset CRUD and L4 firewall writes.
Legacy Analysts are excluded from dedicated SOC gates	Dedicated tier APIs may reject them despite frontend L1 mapping.
L4 escalation mapping/schema is absent	A standard L4 escalation path is unsupported; manager contact and threat review are separate paths.
Capability 29 naming/routing mismatch	The Memory Overflow catalog card may match the TI routing predicate.
The L2 run-playbook handler does not dispatch real execution	Returned success is not evidence of actual endpoint execution.
The L3 detection-draft endpoint is audit-only	The draft response is not a persistent active detection rule; correlation rule APIs are a separate implementation.
Scope enforcement is module-specific	SOC assignment helpers and generic companyId-based APIs behave differently; multi-company SOC context is not equivalent across all modules/socket paths.
Some department filters accept request values	For example, a report route prefers query.departmentId; universal department isolation has therefore not been verified.
Closure review exists in a selected incident route	Plain ticket/alert closures and alternate EDR/correlation edits do not enforce the same audit chain.
SOAR automatic mode skips the human gate	High-risk approval behavior depends on the execution path/mode.
No hard workload maximum is evident	The maxWorkload field/display does not guarantee routing rejection; routing ranks candidates by load.
Some SLA/MTTR metrics are fixed strings	Do not quote “18.5m”, “98.8%” or “15m remaining” as production measurements/SLA guarantees.
External services depend on configuration	Kafka/ClickHouse/Redis/archive/AI/Velociraptor availability must be verified in the live deployment.

Using the access policy

Section 9 summarizes named role gates; it is not a full penetration/security certification. Enforcing a formal least-privilege policy would require subsequent engineering work on route-by-route scope validation and negative access testing. This document distinguishes intended responsibilities from observed code behavior.

A live staff directory and effective per-person grants require actual user, company assignment, department assignment and shift records. Repository-only review cannot confirm any real employee's current access. [S1–S15]

24. Source map and glossary

The paths below are relative to the repository. They are the primary references for the factual workflow and permission claims in this document.

Ref	Source files / focus
S1	backend/src/models/User.model.js; backend/src/middleware/auth.middleware.js — roles, account fields, common gates
S2	backend/src/services/socAccess.service.js — company/department scope, queue filter, required role
S3	backend/src/routes/soc.routes.js; backend/src/routes/user.routes.js — invitations, acceptance, staff/user management
S4	backend/src/routes/soc-manager.routes.js — manager access, analysts, shifts, queue, assignment, reports
S5	backend/src/routes/soc-dashboard.routes.js; backend/src/models/SocEscalation.model.js; backend/src/models/SocIncidentAuditReview.model.js — case actions, escalation, closure review
S6	backend/src/routes/l1.routes.js; backend/src/routes/l2.routes.js; backend/src/routes/l3.routes.js — tier-specific operations
S7	backend/src/services/socTicketAssignment.service.js; backend/src/services/socCaseExclusivity.service.js — ticket routing and exclusive case claim
S8	backend/src/routes/soar.routes.js; backend/src/services/soar.service.js; backend/src/routes/auto-response.routes.js; backend/src/services/automatedResponse.service.js — automation, approvals, response
S9	backend/src/middleware/encryptionAccess.js; backend/src/routes/encryption.routes.js; backend/src/services/encryptionScope.service.js; backend/src/routes/forensics.routes.js — crypto, scope, evidence
S10	backend/src/routes/agent.routes.js; backend/src/routes/system.routes.js; backend/src/routes/department.routes.js; backend/src/utils/agentEntitlement.js; backend/src/utils/subscriptionEntitlement.js — assets, agents, entitlements
S11	backend/src/services/correlation.service.js; backend/src/routes/correlation.routes.js; backend/src/models/EdrIncident.model.js; backend/src/workers/alertIngestion.worker.js — detection, incidents, broker processing
S12	backend/src/routes/partner.routes.js; backend/src/routes/auth.routes.js; backend/src/routes/company.routes.js — company/partner onboarding and business operations
S13	company/src/config/menuConfig.js; company/src/App.jsx; company/src/utils/capabilityMap.js — role menus and 31 capability catalog
S14	backend/soc-agent/agent.py; backend/soc-agent/core/; backend/soc-agent/collectors/; docs/implementation/capability-evidence.md — collectors, transport, optional infrastructure
S15	backend/src/routes/soc-chat.routes.js; backend/src/routes/report.routes.js; backend/src/services/dailyReport.service.js; backend/src/security/socketAuthorization.js; backend/src/routes/firewall.routes.js; backend/src/routes/ids.routes.js; backend/src/routes/ips.routes.js; backend/src/routes/edr.routes.js; backend/src/routes/soc-agent-edr.routes.js — communication, reports, network and alternate APIs

Glossary

SOC: Security Operations Center. **SIEM:** centralized security-event monitoring. **EDR:** Endpoint Detection and Response. **SOAR:** Security Orchestration, Automation and Response. **IOC:** suspicious/malicious indicator such as IP, domain or hash. **TI:** Threat Intelligence. **RCA:** Root Cause Analysis. **MFA:** Multi-Factor Authentication. **FIM:** File Integrity Monitoring. **UEBA:** User and Entity Behavior Analytics. **IDS/IPS:** Intrusion Detection / Prevention System. **WAF:** Web Application Firewall. **Scope:** authorized data boundary. **Triage:** initial validation and prioritization. **Chain of custody:** a record of who handled evidence, when and through which actions.

Document date: 3 October 2026. **Basis:** current local source checkout; deployment state and the permission inventory of real users are outside this review.